

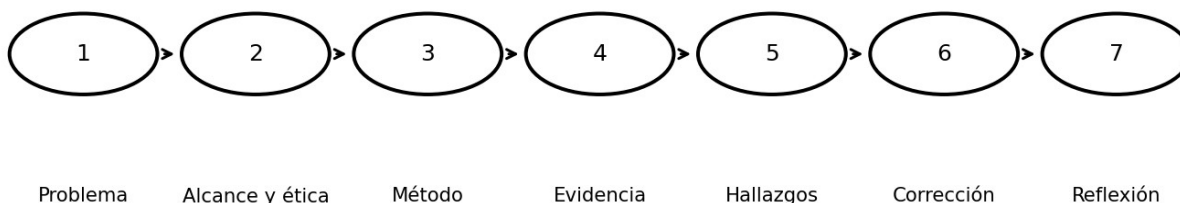
CÓMO CREAR UN PORTAFOLIO DE CIBERSEGURIDAD EN GITHUB

Guía práctica sobre repositorios, estudios de caso, evidencia, seguridad, accesibilidad y presentación profesional

Alberto (Al) Leiva

Versión 1.0 - Julio de 2026

Un portafolio sólido de ciberseguridad cuenta una historia completa



Muestre qué hizo, por qué importó, cómo mantuvo la autorización y qué aprendió.

CC BY-NC-SA 4.0

Propósito y aviso de uso responsable

Este manual ayuda a estudiantes y profesionales a crear un portafolio público de ciberseguridad sin exponer información sensible ni tergiversar la experiencia. Está destinado a trabajos legales, autorizados y éticos.

Regla de seguridad: Nunca publique información confidencial, credenciales reales, detalles de explotación de sistemas sin corregir ni evidencia que no tenga autorización para divulgar.

Tabla de contenido

- 1. Por qué importa un portafolio de ciberseguridad
- 2. Seguridad, autorización, privacidad y ética
- 3. Defina el puesto objetivo y la estrategia
- 4. Cree y proteja su cuenta de GitHub
- 5. Cree un README profesional para el perfil
- 6. Arquitectura y nombres de repositorios
- 7. Escriba un README que demuestre criterio profesional
- 8. Proyecto 1 - Evaluación de riesgos
- 9. Proyecto 2 - Triage SOC y caso de incidente
- 10. Proyecto 3 - Ingeniería de detección
- 11. Proyecto 4 - Revisión de seguridad en la nube
- 12. Proyecto 5 - Seguridad y gobierno de IA
- 13. Proyecto 6 - Política, estándar y procedimiento
- 14. Evidencia sin revelar información sensible
- 15. Git, ramas, issues y pull requests
- 16. GitHub Actions y automatización segura
- 17. Funciones de seguridad del repositorio
- 18. Accesibilidad y documentación inclusiva
- 19. Publique con GitHub Pages y releases
- 20. Revisión de calidad antes de publicar
- 21. Integración con currículum, LinkedIn y entrevistas
- 22. Plan de 30, 60 y 90 días
- 23. Plantillas y listas de verificación
- 24. Referencias oficiales

Estructura recomendada del repositorio de portafolio

portafolio-ciberseguridad/

- |— README.md
- |— 01-evaluacion-riesgos/
- |— 02-ingenieria-deteccion/
- |— 03-respuesta-incidentes/
- |— 04-seguridad-nube/
- |— 05-seguridad-ia/
- |— docs/
- |— LICENSE
- |— SECURITY.md

1. Por qué importa un portafolio de ciberseguridad

Un currículum indica lo que una persona afirma saber. Un portafolio muestra cómo piensa, documenta, comunica y mejora. Es especialmente útil para estudiantes, personas que cambian de carrera, profesionales que se trasladan a una nueva especialidad y candidatos cuyo mejor trabajo no cabe en una sola página.

El portafolio no debe ser una vitrina de trofeos. Debe demostrar criterio. Los proyectos sólidos explican el problema empresarial, la autorización, el alcance, el método, la evidencia, los hallazgos, las limitaciones, las recomendaciones y las lecciones aprendidas.

2. Seguridad, autorización, privacidad y ética

Publique únicamente trabajo creado en un entorno propio, un laboratorio aprobado, una plataforma de formación autorizada o un trabajo profesional que permita expresamente la publicación. La capacidad técnica no crea autorización.

Nunca cargue archivos de clientes, datos de empleadores, capturas con nombres, direcciones IP, tokens, claves privadas, arquitectura interna, detalles de vulnerabilidades, registros de clientes o información protegida por confidencialidad.

3. Defina el puesto objetivo y la estrategia

Elija un puesto objetivo antes de crear proyectos. Un portafolio para analista SOC debe ser diferente de uno para GRC, seguridad en la nube, pruebas de penetración, forense digital, seguridad de IA o arquitectura.

Use una estrategia sencilla: tres proyectos fuertes relacionados con el puesto, un proyecto transversal que demuestre comunicación empresarial y un proyecto de aprendizaje que muestre curiosidad y crecimiento.

Puesto objetivo	Evidencia adecuada
Analista SOC	Casos de triaje, cronologías, detecciones y escalamiento
Analista GRC	Registros de riesgos, pruebas de controles, políticas y mapas de evidencia
Seguridad en la nube	Arquitectura, revisión IAM, registros y postura
Seguridad de IA	Amenazas, pruebas RAG, controles de agentes y gobierno
Arquitecto de seguridad	Arquitecturas, compensaciones y mapeos de controles

4. Cree y proteja su cuenta de GitHub

Use un nombre de usuario profesional, un nombre visible reconocible, una biografía breve y enlaces a LinkedIn o a un sitio personal. Active la autenticación multifactor y proteja los métodos de recuperación.

Utilice credenciales separadas para laboratorios y demostraciones. No reutilice credenciales de producción. Trate los repositorios públicos como permanentemente públicos.

5. Cree un README profesional para el perfil

Un README de perfil aparece cuando existe un repositorio público con el mismo nombre que su usuario de GitHub. Úselo para explicar su función, especialidades, certificaciones, proyectos seleccionados, aprendizaje actual, idiomas y forma de contacto.

Mantenga el perfil fácil de leer. Los reclutadores deben entender su valor en la primera pantalla. Enlace entre tres y seis proyectos destacados.

6. Arquitectura y nombres de repositorios

Use nombres predecibles, carpetas numeradas y formatos coherentes. El lector debe saber dónde comenzar sin abrir cada archivo.

Cada repositorio debe incluir README, licencia, archivos del proyecto, evidencia desidentificada y una nota clara sobre uso autorizado. Para herramientas o scripts, agregue SECURITY.md.

7. Escriba un README que demuestre criterio profesional

El README suele ser el primer y único archivo que lee un evaluador. Escríbalo como un estudio de caso breve, no como una lista de comandos.

Incluya problema, objetivo, alcance, autorización, entorno, arquitectura, herramientas, método, evidencia, hallazgos, recomendaciones, limitaciones, habilidades demostradas e instrucciones para una reproducción segura.

- Título y resultado en una oración
- Problema empresarial o de aprendizaje
- Autorización y alcance
- Entorno y supuestos
- Diagrama de arquitectura o flujo
- Herramientas y datos
- Método y validación
- Hallazgos y severidad
- Recomendaciones y prioridades
- Limitaciones
- Habilidades demostradas
- Pasos de reproducción segura

8. Proyecto 1 - Evaluación de riesgos

Cree una pequeña empresa u organización sin fines de lucro ficticia y realice una evaluación estructurada. Documente activos, amenazas, vulnerabilidades, probabilidad, impacto, controles, tratamiento, responsables y fechas.

Publique un registro de riesgos desidentificado, resumen ejecutivo, mapa de calor, recomendaciones y una reflexión sobre cómo las prioridades del negocio cambiaron sus decisiones.

9. Proyecto 2 - Triage SOC y caso de incidente

Use un laboratorio autorizado o registros de ejemplo para investigar phishing, un inicio de sesión sospechoso, malware o un viaje imposible. Cree una línea de tiempo y explique la evidencia que apoya o debilita cada hipótesis.

Publique un resumen, cronología, indicadores, mapeo MITRE ATT&CK, recomendaciones de contención, decisión de escalamiento y lecciones. No publique datos reales de víctimas.

10. Proyecto 3 - Ingeniería de detección

Cree una regla de detección a partir de un comportamiento de amenaza. Explique la fuente de datos, campos, lógica, falsos positivos, ajustes, validación y respuesta.

Puede usar Sigma, Microsoft Sentinel, Splunk, Elastic o Wazuh. Incluya datos de prueba sintéticos o aprobados.

11. Proyecto 4 - Revisión de seguridad en la nube

Cree un laboratorio pequeño en Azure, AWS o Google Cloud y revise identidad, registros, exposición de red, permisos de almacenamiento, cifrado, secretos y monitoreo.

Publique un diagrama, tabla de hallazgos, capturas desidentificadas, plan de corrección y mapeo a un estándar reconocido.

12. Proyecto 5 - Seguridad y gobierno de IA

Diseñe un asistente, sistema RAG o agente ficticio. Documente flujos de datos, amenazas, inyección de instrucciones, permisos de herramientas, privacidad, supervisión humana, monitoreo e incidentes.

Publique un registro de inventario, evaluación de riesgos, arquitectura, plan de pruebas, resultados y lista de gobierno.

13. Proyecto 6 - Política, estándar y procedimiento

Escriba un paquete práctico para una organización ficticia. Puede cubrir uso aceptable, control de acceso, incidentes, terceros, uso de IA, vulnerabilidades o clasificación de datos.

Muestre la relación entre política, estándar, procedimiento, evidencia y propiedad. No copie plantillas sin adaptarlas al contexto.

14. Evidencia sin revelar información sensible

La evidencia puede incluir diagramas, capturas desidentificadas, registros de ejemplo, datos sintéticos, salida de comandos, fragmentos de configuración, resultados y comparaciones.

Elimine nombres, inquilinos, direcciones IP, tokens, claves, correos, identificadores, clientes, geolocalización y detalles propietarios. Cuando exista duda, recree la evidencia con datos sintéticos.

Puede publicar	No publique
Registros sintéticos	Registros reales de clientes
Capturas desidentificadas	Tokens, claves o cookies

Arquitectura ficticia	Diagramas internos
Hallazgos de laboratorio	Detalles de vulnerabilidades no coordinadas

15. Git, ramas, issues y pull requests

Use commits para mostrar progreso. Escriba mensajes claros como “Agregar tabla de tratamiento de riesgos”. Use ramas para cambios significativos y pull requests para explicar decisiones y pruebas.

Los issues pueden registrar trabajo, defectos, preguntas e ideas. Un historial bien mantenido demuestra capacidad de colaboración.

16. GitHub Actions y automatización segura

La automatización puede validar enlaces, ejecutar pruebas, revisar código, analizar dependencias, construir documentación o publicar GitHub Pages. Mantenga los flujos sencillos y explíquelos.

Use permisos mínimos, referencias inmutables cuando corresponda, protección de entornos, evite entradas no confiables en scripts y nunca imprima secretos.

17. Funciones de seguridad del repositorio

Active las funciones disponibles que se ajusten al proyecto, como alertas de dependencias, actualizaciones, análisis de código, análisis de secretos y políticas de seguridad. La disponibilidad depende del tipo de repositorio y del plan.

Considere comprometida cualquier credencial expuesta. Revoque o rote inmediatamente; eliminarla del último commit no elimina necesariamente el historial.

18. Accesibilidad y documentación inclusiva

Use encabezados significativos, enlaces descriptivos, texto alternativo, contraste legible, lenguaje sencillo, subtítulos y alternativas textuales. No dependa únicamente del color.

Ofrezca DOCX o PDF cuando sea útil, pero mantenga Markdown como fuente accesible. Explique abreviaturas y facilite la navegación con teclado.

19. Publique con GitHub Pages y releases

GitHub Pages puede convertir un repositorio en un sitio estático. Úselo como página principal y para navegar hacia los proyectos.

Use releases para versiones estables de manuales, plantillas, datos o herramientas. Adjunte únicamente artefactos desidentificados y use versiones coherentes.

20. Revisión de calidad antes de publicar

Verifique cada enlace, nombre, captura, instrucción y afirmación. Pregunte si otra persona puede reproducir el trabajo de forma segura, entender las limitaciones y distinguir hechos de supuestos.

Revise ortografía y gramática, valide código, pruebe descargas, compruebe lectura móvil y solicite revisión técnica y de claridad.

21. Integración con currículum, LinkedIn y entrevistas

Agregue una sección de proyectos seleccionados al currículum con un resultado breve y enlace directo. En LinkedIn, destaque los repositorios más fuertes y explique el problema resuelto.

En entrevistas, use el portafolio para explicar decisiones, compensaciones, fallas y mejoras. Nunca presente un laboratorio como experiencia de producción.

22. Plan de 30, 60 y 90 días

En los primeros 30 días, proteja la cuenta, cree el README de perfil, elija un puesto objetivo y publique un proyecto pulido. Para el día 60, agregue dos proyectos alineados. Para el día 90, publique un proyecto transversal, solicite comentarios e integre el portafolio en solicitudes y entrevistas.

La calidad es más importante que el volumen. Mantenga y mejore lo existente en lugar de crear muchos repositorios incompletos.

Periodo	Entregable
Días 1-30	README de perfil y un proyecto pulido
Días 31-60	Dos proyectos alineados y mejoras
Días 61-90	Proyecto transversal, comentarios e integración laboral

23. Plantillas y listas de verificación

Plantilla de README de proyecto

- Título y resultado
- Problema
- Autorización y alcance
- Entorno

- Arquitectura
- Herramientas
- Método
- Evidencia
- Hallazgos
- Recomendaciones
- Limitaciones
- Lecciones
- Referencias
- Licencia

Lista antes de publicar

- ☐ Sin secretos ni credenciales
- ☐ Sin datos confidenciales o personales
- ☐ Autorización documentada
- ☐ Enlaces probados
- ☐ Archivos correctos
- ☐ Ortografía y gramática revisadas
- ☐ Texto alternativo incluido
- ☐ Afirmaciones respaldadas
- ☐ Limitaciones declaradas
- ☐ Licencia seleccionada
- ☐ Contacto apropiado

24. Referencias oficiales

[GitHub profile README](#)

[Creating and managing repositories](#)

[GitHub Pages](#)

[Quickstart for securing a repository](#)

[Secret scanning](#)

[Code scanning alerts](#)

[Security for GitHub Actions](#)

[Artifact attestations](#)

Licencia y atribución

Copyright © 2026 Alberto (Al) Leiva. Licencia Creative Commons Atribución-NoComercial-CompartirIgual 4.0 Internacional.